

AUDSPECT

Breach & Attack Simulation Platform

Adversary Simulation Assessment Report

Endpoint Mastery 01 — Endpoint Security Control Validation

RISK: HIGH RISK

Prepared for	WIN-MHQITQ23L3Q
Endpoint	Windows/amd64 (10.0.17763)
Environment	Production
Assessment date	18 June 2026, 10:49 UTC
Report generated	18 June 2026, 11:05 UTC
Run reference	18ba273d

1. Executive Summary

PRODUCTION ENVIRONMENT

This assessment executed live adversary techniques against a production endpoint. Endpoint changes were reverted where the snapshot system captured them — see section 7 (Changes & Cleanup Verification).

This report presents the results of an automated breach & attack simulation executed against WIN-MHQITQ23L3Q (Windows/amd64 (10.0.17763)) on 18 June 2026. The assessment ran 7 MITRE ATT&CK-aligned techniques to measure how effectively the endpoint's security controls prevent real adversary behaviour.

Of the techniques executed, 2 were prevented or blocked by a security control and 4 executed successfully without being stopped. This yields a prevention effectiveness of 33% and an overall risk classification of High Risk (risk score 67/100). A further 0 technique(s) could not be evaluated (execution errors — malformed test content, timeouts, missing prerequisites or scheduler contention) and 1 were skipped; both are excluded from the prevention and exposure scores so they neither inflate nor deflate the result.

4 critical or high-severity technique(s) were not prevented and require prioritised remediation (see Key Findings). Testing exercised 2 of the 14 MITRE ATT&CK Enterprise tactics across 7 technique(s) — this is the breadth of THIS run, not a measure of overall MITRE ATT&CK coverage. Broadening scenario coverage in future runs will increase assurance. Prioritised recommendations are provided in section 8.

Overall posture: High Risk (risk score 67 / 100, Baseline)

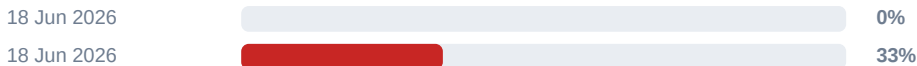
7 techniques · 2 prevented · 4 succeeded · 0 errored · 1 skipped · 4 critical/high finding(s)

Trend vs Previous Assessment

Prevention effectiveness is 33% this run versus 0% in the previous assessment.

IMPROVED +33 PTS

Prevention over the last 2 assessments (oldest to newest):



Prevention & Detection

4 technique(s) executed without being prevented. A FAIL means a prevention control did not stop execution — not that the attacker's end objective was independently verified. Of those that executed:

Detection results unavailable: no host telemetry was collected during this run.

This is a measurement gap, not proof the techniques evaded detection. Confirm the agent build collects event-log telemetry and that Microsoft Defender (or Sysmon) is enabled on the endpoint, then re-run. The figures below reflect prevention only; the detection split cannot be trusted until telemetry is collected.

0	Detected	an alert fired (Microsoft Defender) — a SOC would see this
0	Logged only	telemetry exists but no alert was raised
4	Undetected	detection not measured — no telemetry collected this run (see caveat above)

Business-Objective Risk

What an attacker could achieve against this endpoint, by objective — derived from the tested techniques in each area (execution errors excluded).

Defense Evasion	HIGH RISK	3 of 5 technique(s) unprevented
Code Execution	HIGH RISK	1 of 1 technique(s) unprevented

2. Assessment Scorecard



Tactic breadth: 2 / 14 · Defense rate: 0% · Mean time-to-detect: — · Result confidence: High (6 valid of 7 attempted, 0 errored)

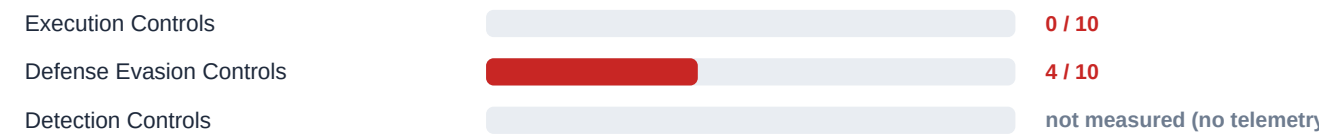
Assessment Insights



No host telemetry was collected this run — detection effectiveness could not be measured (the agent may be offline or an older build). Undetected counts reflect missing measurement, not confirmed evasion.

Control Maturity by Category

Maturity (0–10) per control family, from this run's prevention rate — a management view of which controls held and which need investment. Derived from tested techniques only.



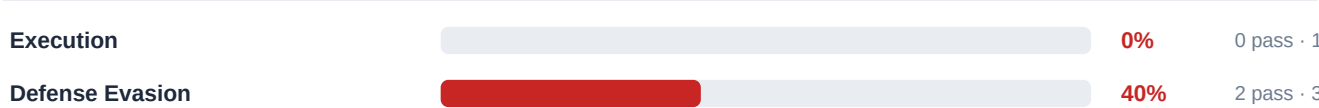
3. Methodology & Scope

Framework	MITRE ATT&CK (Enterprise)
Engines	Custom checks
Target endpoint	WIN-MHQITQ23L3Q — Windows/amd64 (10.0.17763)
Asset class	Workstation (inferred from OS)
Environment	Production
Business criticality	High — production endpoint
Security context	Microsoft Defender (real-time protection OFF)
Techniques executed	7
Tactics exercised	2 of 14 ATT&CK tactics
Window	18 Jun 2026 10:49 UTC

Security context lists the AV/EDR products detected on the endpoint (presence only). Detection by third-party EDR is not locally observable and is therefore never asserted in this report.

Each technique is scored as PASS when a security control prevented or blocked it, FAIL when it executed without being stopped, ERROR when the test itself could not execute correctly (malformed content, timeout, missing prerequisite, scheduler contention), or SKIPPED when it was not run. Only PASS and FAIL count toward the score: a FAIL is a finding — the simulated adversary behaviour succeeded against this endpoint — while ERROR and SKIPPED are excluded because they reflect a test-execution problem, not the endpoint's defences.

4. ATT&CK Tactic Breakdown



5. Key Findings

Top Risk Drivers

Techniques whose failures account for the most lost prevention points (the points each accounts for, not a promised gain from any single fix).

1. T1562.001 Impair Defenses: Disable or Modify Tools (Defense Evasion)
2. T1059.001 Command and Scripting Interpreter: PowerShell (Execution)

50.0 PTS · 3F · HIGH**16.7 PTS · 1F · HIGH**

Realized Attack Path

The unprevented techniques from this run, ordered by kill-chain phase. An attacker chaining these consecutive phases met limited resistance — this is the path the endpoint's gaps actually permit, derived from observed FAILs (no inferred causal links).

Execution

T1059.001 — Command and Scripting Interpreter: PowerShell

Defense Evasion

T1562.001 — Impair Defenses: Disable or Modify Tools

HIGH

F-01 T1562.001 — Impair Defenses: Disable or Modify Tools

Defense Evasion

What happened Defender real-time protection is DISABLED - endpoint is unprotected against on-access threats.

Remediation

- 1) Enable tamper protection on all EDR/AV solutions; alert on protection disablement.
- 2) Restrict PowerShell to ConstrainedLanguageMode and enable AMSI.
- 3) Enable Script Block Logging (Event ID 4104) and forward to SIEM.
- 4) Monitor for security service termination and log clearing events.

Threat Intelligence (MITRE ATT&CK)

Known threat actors	APT29, Agrius, Aquatic Panda, BRONZE BUTLER, Ember Bear, FIN6, Gamaredon Group, Gorgon Group, INC Ransom, Indrik Spider, +5 more
Associated malware/tools	Agent Tesla, Avaddon, Babuk, Bazar, Brave Prince, Bundlore, Carberp, ChChes, Clop, Cobalt Strike, +5 more
Mitigations (ATT&CK)	Execution Prevention; Restrict File and Directory Permissions; Restrict Registry Permissions; User Account Management
Platforms	Windows, macOS, Linux, Containers, IaaS, Network
Detection data sources	Command: Command Execution; Driver: Driver Load; Process: Process Creation; Process: Process Termination; Sensor Health: Host Status; Service: Service Metadata; Windows Registry: Windows Registry Key Deletion; Windows Registry: Windows Registry Key Modification
Windows telemetry (Sysmon/WEL)	Sysmon 1, Windows Security 4688, PowerShell 4104, Sysmon 6, Sysmon 5, Sysmon 12-14, Windows Security 4657
ATT&CK version	v1.5 · created 2020-02-21 · updated 2024-04-12
ATT&CK reference	https://attack.mitre.org/techniques/T1562/001

HIGH

F-02 T1059.001 — Command and Scripting Interpreter: PowerShell

Execution

What happened No application control (AppLocker/WDAC) detected - any binary or script is allowed to execute.

Remediation

- 1) Enable PowerShell Script Block Logging and Constrained Language Mode.
- 2) Implement application allowlisting (AppLocker/WDAC) to restrict code execution.
- 3) Enable ASR rules targeting script-based and macro-based execution.
- 4) Monitor for anomalous parent-child process relationships in EDR.

Threat Intelligence (MITRE ATT&CK)

Known threat actors	APT19, APT28, APT29, APT3, APT32, APT33, APT38, APT39, APT41, APT5, +5 more
Associated malware/tools	AADInternals, Akira, AppleSeed, AutoIt backdoor, BADHATCH, BONDUPDATER, Bandook, Bazar, Black Basta, BloodHound, +5 more
Mitigations (ATT&CK)	Antivirus/Antimalware; Code Signing; Disable or Remove Feature or Program; Execution Prevention; Privileged Account Management
Platforms	Windows
Detection data sources	Command: Command Execution; Module: Module Load; Process: Process Creation; Process: Process Metadata; Script: Script Execution
Windows telemetry (Sysmon/WEL)	Sysmon 1, Windows Security 4688, PowerShell 4104, Sysmon 7
ATT&CK version	v1.4 · created 2020-03-09 · updated 2024-10-15
ATT&CK reference	https://attack.mitre.org/techniques/T1059/001

Adversary Knowledge Graph

Threat actors and malware known (per MITRE ATT&CK) to use the techniques that went unprevented in this run, ranked by how many of those techniques they cover — the real-world adversaries these gaps expose you to.

Threat actors that use these techniques

APT29	2 technique(s): T1059.001, T1562.001
Aquatic Panda	2 technique(s): T1059.001, T1562.001
BRONZE BUTLER	2 technique(s): T1059.001, T1562.001
APT19	1 technique(s): T1059.001
APT28	1 technique(s): T1059.001
APT3	1 technique(s): T1059.001
APT32	1 technique(s): T1059.001
APT33	1 technique(s): T1059.001

Malware / tools that implement these techniques

Bazar	2 technique(s): T1059.001, T1562.001
Cobalt Strike	2 technique(s): T1059.001, T1562.001
AADInternals	1 technique(s): T1059.001
Agent Tesla	1 technique(s): T1562.001
Akira	1 technique(s): T1059.001
AppleSeed	1 technique(s): T1059.001
Autolt backdoor	1 technique(s): T1059.001
Avaddon	1 technique(s): T1562.001

Threat-intelligence context derived from MITRE ATT&CK®. © The MITRE Corporation. ATT&CK® is a registered trademark of The MITRE Corporation.

6. Detailed Technique Results

Results are grouped by ATT&CK technique. Each technique shows how many of its tests executed, were blocked, or errored. ERROR tests (a BAS execution problem, not a security outcome) are summarised in the counts and excluded from scoring.

T1562.001 — Impair Defenses: Disable or Modify Tools

Defense Evasion · High · Policy Configuration Check

4 test(s): 3 executed · 1 blocked · 0 errored · 0 skipped

Threat impact	Impair Defenses: Disable or Modify Tools (T1562.001): Attacker disables or bypasses security controls allowing subsequent techniques to execute undetected, defeating SIEM/SOAR alerting and EDR coverage.
Remediation	1) Enable tamper protection on all EDR/AV solutions; alert on protection disablement. 2) Restrict PowerShell to ConstrainedLanguageMode and enable AMSI. 3) Enable Script Block Logging (Event ID 4104) and forward to SIEM. 4) Monitor for security service termination and log clearing events.
FAIL	Defender real-time protection is DISABLED - endpoint is unprotected against on-access threats. Detection: No detection telemetry observed Evidence: FAIL: Defender real-time protection is DISABLED - endpoint is unprotected against on-access threats.
PASS	AV signatures are 1 day(s) old - within freshness window. [BAS-SIM] Blocked by: an active security control (not identifiable from local telemetry)
FAIL	Tamper Protection is OFF - an attacker with admin can silently disable the AV before attacking. Detection: No detection telemetry observed Evidence: FAIL: Tamper Protection is OFF - an attacker with admin can silently disable the AV before attacking.
FAIL	1 ASR rule(s) present but NONE in Block mode (audit-only) - they observe but do not stop attacks. Detection: No detection telemetry observed Evidence: FAIL: 1 ASR rule(s) present but NONE in Block mode (audit-only) - they observe but do not stop attacks.

T1562.004 — Impair Defenses: Disable or Modify System Firewall

Defense Evasion · High · Policy Configuration Check

1 test(s): 0 executed · 1 blocked · 0 errored · 0 skipped

Threat impact	Impair Defenses: Disable or Modify System Firewall (T1562.004): Attacker disables or bypasses security controls allowing subsequent techniques to execute undetected, defeating SIEM/SOAR alerting and EDR coverage.
Remediation	Control validated: Impair Defenses: Disable or Modify System Firewall (T1562.004) was blocked. Maintain current security posture and continue monitoring.
PASS	Host firewall is ENABLED on all profiles (Domain/Private/Public). [BAS-SIM] Blocked by: an active security control (not identifiable from local telemetry)

Execution · High · Policy Configuration Check

1 test(s): 1 executed · 0 blocked · 0 errored · 0 skipped

Threat impact Command and Scripting Interpreter: PowerShell (T1059.001): Attacker executes arbitrary code on the endpoint enabling full control of the compromised system and all data accessible from it.

Remediation

- 1) Enable PowerShell Script Block Logging and Constrained Language Mode.
- 2) Implement application allowlisting (AppLocker/WDAC) to restrict code execution.
- 3) Enable ASR rules targeting script-based and macro-based execution.
- 4) Monitor for anomalous parent-child process relationships in EDR.

FAIL

No application control (AppLocker/WDAC) detected - any binary or script is allowed to execute.

Detection: No detection telemetry observed

Evidence: FAIL: No application control (AppLocker/WDAC) detected - any binary or script is allowed to execute.

T1486 — Data Encrypted for Impact

Impact · High · Policy Configuration Check

1 test(s): 0 executed · 0 blocked · 0 errored · 1 skipped

Threat impact Data Encrypted for Impact (T1486): Attacker disrupts, destroys, or manipulates data — ransomware encryption, wiper deployment, or transaction manipulation affecting business continuity and SEBI/RBI obligations.

Remediation

- 1) Implement and test offline backup strategy (3-2-1 rule) per RBI/SEBI BCP guidelines.
- 2) Enable VSS protection and restrict shadow copy deletion to admin-only with MFA.
- 3) Deploy ransomware-specific EDR detection rules and automated isolation playbooks.
- 4) Maintain and regularly test DR and incident response plans per CSCRf requirements.

7. Changes & Cleanup Verification

The agent reverted 1 endpoint change(s) made during the run. Cleanup status: COMPLETED — each captured change was rolled back from the pre-run snapshot.

- tmp removed: C:\Windows\TEMP\bas-18ba273d2f4ccb77-3621979795

Scope note: residual-artifact tracking covers changes captured by the pre-run snapshot (registry keys and files the engine instruments). Out-of-band changes a technique may make outside that scope are not tracked here — verify manually for high-impact techniques run in production.

8. Action Plan

Ordered by the prevention-score points each tactic's failures account for (severity-weighted, the same weighting as the headline score). The points quantify current exposure — not a guaranteed score gain.

1 Defense Evasion — Defense Evasion

50.0 PTS · 3F

Enable tamper protection, ASR rules, and AMSI; alert on security-tool disabling.

2 Execution — Code Execution

16.7 PTS · 1F

Constrain script engines (PowerShell CLM, WSH) and enforce application control.

Additional Guidance

- 1 Overall prevention score is critically low. Prioritise endpoint hardening and EDR deployment across all assets.
- 2 Exposure score exceeds 60. Deploy a 24x7 SOC with SIEM correlation rules aligned to detected failure patterns.
- 3 Tactic coverage is below 50%. Run additional scenarios (ART full sweep, Caldera lateral movement) to exercise more of the ATT&CK kill chain before next audit.

9. Appendix — Metric Definitions

PASS

A security control prevented or blocked the simulated technique. More passes is better.

FAIL

A prevention control did not stop the technique from executing — a finding requiring attention. This means execution was permitted; it does NOT independently verify the attacker's end

	objective was achieved (e.g. that credentials were actually exfiltrated), which is technique-specific. Check the Detection line for whether the execution was also detected.
Detection	Whether the executed technique was seen by locally-observable telemetry: Detected (a Microsoft Defender alert fired), Logged only (Sysmon/Security telemetry exists but no alert), or Undetected (no telemetry). Third-party EDR detection is not locally observable and is never asserted.
Blocked by	The control credited with blocking a technique, when local evidence (a Microsoft Defender event or a recognisable block signature in the output) supports it. Where no control can be evidenced locally, the report states that an active control blocked it without naming a product — it never guesses.
Trend	Change in prevention effectiveness versus the previous scored assessment for this endpoint, with a short history. Appears once a second assessment has completed.
Threat Intelligence	Per-technique context from MITRE ATT&CK® (threat actors, malware/tools, mitigations) — authoritative, published by MITRE. CVE/KEV/OWASP/CWE shown as 'illustrative' are analyst-curated context, not an authoritative per-technique mapping, and should be read as examples, not an exhaustive list.
ERROR	The test could not execute correctly (malformed content, timeout, missing prerequisite, scheduler contention). A BAS execution problem, not a security outcome — excluded from scoring.
SKIPPED	The technique was deliberately not run (e.g. external payload not shipped) and was excluded from scoring.
Policy Configuration Check	A passive audit that inspects a security setting (registry key, policy, service state) without running an attack — it confirms whether a control is correctly configured.
Active Adversary Behavioral Test	An ART or Caldera test that actually executes the technique on the endpoint — it confirms whether deployed controls stop a live attack, not just whether they are configured.
Prevention	Severity-weighted percentage of techniques that were prevented. Higher is better.
Exposure	Tactic-weighted failure rate, amplified by consecutive kill-chain failures. Lower is better.
Tactic Breadth	Breadth of THIS run: how many of the 14 MITRE ATT&CK Enterprise tactics it exercised. Not a measure of overall MITRE ATT&CK technique coverage — running more Atomics in a tactic does not increase ATT&CK coverage.
Defense Rate	Share of tested tactics in which every technique was blocked (zero failures).
Kill-chain amplifier	Multiplier (1.0–2.5×) reflecting consecutive unprevented kill-chain phases.
Risk classification	Overall posture band derived from the amplified exposure score.